

보안 체크리스트

웹 서비스 보안 점검 39개 항목 | 2026.07

전체 항목 39개

Critical 12개

High 18개

Medium 9개

API 키 & 환경변수 (4개 항목)

No	위험도	점검 항목	설명
1	Critical	.env 파일 노출 여부	.env, .env.local 파일이 Git/공개 저장소에 노출되지 않았는지 확인
2	High	NEXT_PUBLIC_ 오용 여부	서버 전용 시크릿에 NEXT_PUBLIC_ 접두사를 잘못 사용하여 클라이언트에 노출되는지 확인
3	Critical	코드 내 시크릿 하드코딩	API 키, DB 비밀번호, JWT 시크릿 등이 소스코드에 직접 하드코딩되어 있는지 확인
4	High	env 변수 누락 시 fail - closed	필수 환경변수 누락 시 앱이 안전하게 종료(fail - closed)되는지 확인

데이터베이스 보안 (4개 항목)

No	위험도	점검 항목	설명
5	Critical	Supabase RLS 활성화	Supabase Row Level Security가 모든 테이블에 활성화되어 있는지 확인
6	High	Firebase 보안 규칙	Firebase Firestore/Realtime DB의 보안 규칙이 적절히 설정되어 있는지 확인
7	Critical	SQL 인젝션 방지	사용자 입력이 직접 SQL 쿼리에 삽입되지 않고 파라미터화된 쿼리를 사용하는지 확인
8	High	DB 연결 정보 암호화	DB 연결 문자열이 환경변수로 관리되고 암호화 전송(TLS)이 활성화되어 있는지 확인

인증 & 세션 (5개 항목)

No	위험도	점검 항목	설명
9	Critical	JWT verify 서버 검증	JWT 토큰이 클라이언트에서만 검증하지 않고 반드시 서버에서 재검증하는지 확인
10	High	Rate Limiting 적용	로그인 API 등 인증 엔드포인트에 Rate Limiting(요청 제한)이 적용되어 있는지 확인
11	Critical	bcrypt/argon2 해시 사용	비밀번호가 bcrypt, argon2 등 안전한 해시 알고리즘으로 저장되는지 확인 (MD5/SHA1 금지)
12	High	세션 쿠키 보안 속성	세션 쿠키에 HttpOnly, Secure, SameSite 속성이 올바르게 설정되어 있는지 확인
13	Medium	세션 만료 및 무효화	로그아웃 시 서버 세션이 완전히 무효화되고 적절한 세션 만료 시간이 설정되어 있는지 확인

입력값 & API 보안 (5개 항목)

No	위험도	점검 항목	설명
14	Critical	XSS 방지	사용자 입력이 HTML에 직접 렌더링되지 않고 이스케이프/새니타이징 처리되는지 확인
15	High	CORS 설정	API 서버의 CORS가 허용 도메인만 화이트리스트로 설정되어 있는지 확인 (와일드카드 금지)

No	위험도	점검 항목	설명
16	High	파일 업로드 검증	파일 업로드 시 확장자, MIME 타입, 파일 크기 검증이 서버 측에서 이루어지는지 확인
17	Critical	금액/수량 서버 재검증	가격, 수량 등 중요 데이터가 클라이언트 값을 신뢰하지 않고 서버에서 재계산/검증하는지 확인
18	Critical	API 인증 미들웨어	모든 보호된 API 엔드포인트에 인증 미들웨어가 적용되어 있는지 확인

설정 & 인프라 (4개 항목)			
No	위험도	점검 항목	설명
19	High	HTTPS 강제 적용	모든 통신이 HTTPS로 이루어지고 HTTP -> HTTPS 리다이렉트가 설정되어 있는지 확인
20	Critical	관리자 페이지 접근 제한	/admin 등 관리자 페이지가 공개적으로 노출되지 않고 IP 제한 또는 강력한 인증이 적용되어 있는지 확인
21	Medium	npm audit 취약점	의존성 패키지에 알려진 보안 취약점(CVE)이 없는지 npm audit으로 확인
22	Medium	Security Headers 설정	CSP, X-Frame-Options, X-Content-Type-Options 등 보안 HTTP 헤더가 설정되어 있는지 확인

개인정보보호법 (10개 항목)			
No	위험도	점검 항목	설명
23	High	개인정보 수집 동의	개인정보 수집 시 명시적 동의를 받고 목적 외 사용을 제한하는 절차가 있는지 확인
24	Medium	개인정보 처리방침 게시	개인정보 처리방침이 서비스 내에 명확히 게시되어 있는지 확인
25	Critical	개인정보 암호화 저장	주민번호, 비밀번호 등 민감 정보가 암호화되어 저장되는지 확인
26	High	개인정보 파기 절차	서비스 탈퇴 또는 보유 기간 만료 시 개인정보가 안전하게 파기되는지 확인
27	Medium	제3자 제공 고지	개인정보를 제3자에게 제공하는 경우 별도 동의를 받고 있는지 확인
28	High	열람/정정/삭제 권리 보장	정보주체(이용자)가 자신의 개인정보를 열람/정정/삭제 요청할 수 있는 절차가 마련되어 있는지 확인 (개인정보보호법 제35~37조)
29	Critical	개인정보 유출 통지 절차	개인정보 침해/유출 사고 발생 시 72시간 내 정보주체 및 보호위원회에 통지하는 절차가 수립되어 있는지 확인 (제34조)
30	High	처리 위탁 관리 (수탁자)	Vercel/Supabase 등 개인정보 처리 위탁업체와 위탁 계약을 체결하고 관리/감독하는지 확인 (제26조)
31	High	접근 권한 최소화	개인정보 처리 시스템에 업무상 필요한 최소한의 권한만 부여하고 불필요한 접근을 차단하는지 확인 (제29조)
32	Medium	개인정보 처리 내역 기록	개인정보 수집/이용/제공/파기 등 처리 내역을 기록하고 일정 기간 보관하는지 확인 (제30조)

Vercel & Supabase 전용 (7개 항목)			
No	위험도	점검 항목	설명
33	High	자동 백업	DB 데이터 유실에 대비해 정기적인 자동 백업이 구성되어 있는지 확인 (GitHub Actions 또는 Supabase 백업)
34	High	2FA (이중 인증)	Vercel 및 Supabase 대시보드 계정에 2단계 인증(2FA)이 활성화되어 있는지 확인

No	위험도	점검 항목	설명
35	Medium	Connection Pooling	Supabase Session Pooler(IPv4)를 사용하여 DB 연결 안정성과 보안을 확보하는지 확인
36	Medium	로그 모니터링	Vercel Analytics 또는 로그를 통해 비정상 접근/오류를 모니터링하는 체계가 갖춰져 있는지 확인
37	High	Supabase API DISABLED	민감 테이블(risk_entries, users, audit_logs 등)의 Supabase REST API가 비활성화되어 외부 직접 호출을 차단하는지 확인
38	High	anon 권한 최소화	Supabase anon role의 테이블 접근 권한을 REVOKE하여 익명 사용자의 데이터 접근을 차단하는지 확인
39	Medium	Network Restrictions	Supabase DB 접속을 허용 IP 대역으로만 제한하여 외부 직접 연결을 차단하는지 확인 (Vercel Pro 필요)

본 체크리스트는 Next.js + Vercel + Supabase 아키텍처 기반 웹 서비스 보안 점검 항목입니다. | 작성일: 2026.07.08